

CONFIDENTIAL

Security Assessment Report

Web Application Penetration Test

PROJECT	TEST-WEBSITE-Jun2026-Orc
TARGET(S)	44.228.249.3:80, 44.228.249.3:443, 44.228.249.3:4443, 44.228.249.3:8443
ASSESSMENT TYPE	External Web Application Penetration Test
TESTING PERIOD	June 2026
REPORT DATE	10 June 2026
OVERALL RISK	Medium

This report contains confidential information. Distribution is restricted to authorized personnel only.
TechGuard Labs • hari@techguardlabs.com

01 Executive Summary

Overall Risk Rating **MEDIUM** The overall risk is rated Medium because the single confirmed finding — missing HTTP security headers — does not provide direct system compromise capability but meaningfully increases user exposure to clickjacking, MIME-sniffing, and cross-site scripting attacks, particularly in the absence of compensating controls.

TechGuard Labs conducted an external web application penetration test against testphp.vulnweb.com (44.228.249.3) during June 2026. The assessment covered DNS reconnaissance, network port scanning, TLS configuration review, web application enumeration, and API security testing across 18 web and 20 API test cases. One medium-severity finding was identified: the absence of multiple HTTP security headers that protect end users from common browser-based attacks. No critical or high-severity vulnerabilities were confirmed during automated testing; however, the missing security headers represent a tangible and easily remediated exposure that should be addressed promptly.

0

CRITICAL

0

HIGH

1

MEDIUM

0

LOW

1

INFO

02 Scope & Methodology

TARGET SCOPE

Host / IP	Port(s)	Protocol	Application
44.228.249.3	443, 4443, 8443	HTTPS	Web Application
testphp.vulnweb.com	443	HTTPS	Web Application

TESTING PHASES

Phase	Activity	Tools
01 DNS Recon	Domain enumeration, subdomain discovery	dig, subfinder, dnsx
02 IP Analysis	ASN, geolocation, cloud provider, WHOIS	whois, ipinfo
03 Network Scan	Port scanning, service fingerprinting	nmap
04 TLS Assessment	Certificate analysis, cipher enumeration	testssl.sh
05 Web Enumeration	Header analysis, WAF detection, content discovery	curl, wafw00f, gobuster, nikto
06 WordPress Scan	Plugin/theme enumeration, CVE checks	wpscan
07 Service Verification	Manual probing of open services	Manual
08 Application API	Rate limiting, auth bypass, API enumeration	curl, python-requests
09 AI/LLM Endpoints	Prompt injection, data exfiltration probes	PT-Orc AI Skill

TOOLS & FRAMEWORKS

nmap	masscan	nikto	testssl.sh	wafw00f	gobuster	ffuf	httpx	amass	nuclei	metasploit-framework
------	---------	-------	------------	---------	----------	------	-------	-------	--------	----------------------

03 Risk Analysis

RISK MATRIX — LIKELIHOOD × IMPACT

	LOW IMPACT	MEDIUM IMPACT	HIGH IMPACT
HIGH LIKELIHOOD	MEDIUM	HIGH	CRITICAL
MEDIUM LIKELIHOOD	LOW	MEDIUM F-001	HIGH
LOW LIKELIHOOD	INFO	LOW	MEDIUM

OWASP TOP 10 2021 — COVERAGE MAP

Code	Category	Coverage	Count
A01	Broken Access Control		0
A02	Cryptographic Failures		0
A03	Injection		0
A04	Insecure Design		0
A05	Security Misconfiguration		2
A06	Vulnerable and Outdated Components		0
A07	Identification and Authentication Failures		0
A08	Software and Data Integrity Failures		0
A09	Security Logging and Monitoring Failures		0
A10	Server-Side Request Forgery		0

F-001 Multiple HTTP Security Headers Missing

MEDIUM

CVSS 3.1

5.4

OWASP 2021

A05 — Security Misconfiguration

CWE

CWE-693 — Protection Mechanism Failure

CONFIDENCE

Confirmed

AFFECTED HOSTS

44.228.249.3:443

44.228.249.3:4443

44.228.249.3:8443

DESCRIPTION

Security header analysis identified 14 missing HTTP response security headers across the web application hosted at testphp.vulnweb.com. The absent headers include, but are not limited to: Content-Security-Policy (CSP), X-Frame-Options, X-Content-Type-Options, Strict-Transport-Security (HSTS), X-XSS-Protection, Referrer-Policy, Permissions-Policy, and Cross-Origin resource policy headers. These headers instruct the browser to enforce security constraints that mitigate a wide class of client-side attacks. Their collective absence means that no browser-enforced defence layer exists against clickjacking, MIME-type confusion attacks, reflected or stored cross-site scripting, protocol downgrade attacks, and sensitive data leakage via the Referer header.

TECHNICAL DETAIL

Automated security header analysis (evidence file: sec_headers_4443_20260610_141914.txt) confirmed the absence of 14 security-relevant HTTP response headers on port 4443 (and corroborated on ports 443 and 8443 per TLS assessment session 20260610_141722). A representative curl response demonstrated no Content-Security-Policy, no X-Frame-Options, no X-Content-Type-Options, no Strict-Transport-Security, no X-XSS-Protection, no Referrer-Policy, and no Permissions-Policy headers present in server responses. The omission of HSTS is particularly notable given that TLS is available on multiple ports, as it permits protocol downgrade by an active network attacker. The omission of X-Frame-Options and CSP frame-ancestors allows the application to be embedded in third-party iframes, enabling clickjacking attacks against authenticated users.

BUSINESS IMPACT

Without these protective headers, users visiting the website are more vulnerable to attacks carried out through their own web browser. For example, an attacker could embed the site invisibly inside another page and trick a logged-in user into clicking buttons they cannot see (clickjacking), potentially triggering account changes or financial transactions without their knowledge. Malicious scripts could also execute within the context of the site more easily, risking theft of session tokens or user credentials. These weaknesses could expose the organisation to regulatory scrutiny under data protection frameworks such as GDPR if user data is compromised as a result.

REMEDIATION

Configure the web server or application to return all recommended HTTP security headers with appropriately strict values on every response.

1. Add 'Strict-Transport-Security: max-age=31536000; includeSubDomains; preload' to all HTTPS responses to enforce HTTPS and prevent protocol downgrade attacks.
2. Add 'Content-Security-Policy: default-src \'self\'; script-src \'self\'; object-src \'none\'; frame-ancestors \'none\';' — adjust source directives to match the application's legitimate content origins before enforcing, using report-only mode initially.

3. Add 'X-Frame-Options: DENY' or 'X-Frame-Options: SAMEORIGIN' to prevent clickjacking; note that CSP frame-ancestors supersedes this header in modern browsers but both should be set for legacy compatibility.
4. Add 'X-Content-Type-Options: nosniff' to prevent browsers from MIME-sniffing responses away from the declared Content-Type.
5. Add 'X-XSS-Protection: 1; mode=block' for legacy browser compatibility (modern browsers rely on CSP instead).
6. Add 'Referrer-Policy: strict-origin-when-cross-origin' to limit Referer header leakage to third-party origins.
7. Add 'Permissions-Policy: geolocation=(), microphone=(), camera=()' restricting access to sensitive browser APIs not required by the application.
8. For Apache, add header directives in httpd.conf or .htaccess using the mod_headers module. For Nginx, use the add_header directive in the server or location block. For application-layer injection, implement a middleware or filter that sets headers on all outgoing responses.
9. After deployment, validate the configuration using a browser developer tools network tab or an automated tool such as securityheaders.com and re-run the security header scan to confirm all 14 previously absent headers are now present with correct values.
10. Integrate security header validation into the CI/CD pipeline so that missing or misconfigured headers fail the build before deployment to production.

REFERENCES

<https://owasp.org/www-project-secure-headers/>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Content-Security-Policy>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy>
https://cheatsheetseries.owasp.org/cheatsheets/HTTP-Headers_Cheat_Sheet.html
<https://securityheaders.com>

F-002

Target Hosted on AWS EC2 — Cloud Ownership Verification Required

INFORMATIONAL

CVSS

3.1

0.0

OWASP 2021

A05 — Security

Misconfiguration

CWE

CWE-200 — Exposure of Sensitive Information to an Unauthorized Actor

CONFIDENCE

Confirmed

AFFECTED HOSTS

44.228.249.3

DESCRIPTION

IP analysis confirmed that the target host 44.228.249.3 resolves to an Amazon Web Services EC2 instance in the us-west-2 (Oregon) region (PTR record: ec2-44-228-249-3.us-west-2.compute.amazonaws.com, ASN AS16509, Amazon.com Inc.). Cloud-hosted infrastructure carries specific engagement considerations: the IP may be a shared elastic address, the instance could be terminated and re-assigned, and AWS's Penetration Testing Policy requires that testing activities comply with their Acceptable Use Policy. This is recorded as informational to document that the RoE advisory was acknowledged and that written authorisation confirming client ownership or control of this AWS asset was a prerequisite for active scanning.

TECHNICAL DETAIL

PTR lookup and WHOIS/ASN enrichment performed by 02_ip_analysis.sh (session 20260610_133806) returned: PTR=ec2-44-228-249-3.us-west-2.compute.amazonaws.com, ASN=AS16509, Org=Amazon.com Inc., Country=United States. No Shodan enrichment was available (API key not configured). Traceroute hop count returned an anomalous value of 0, which may indicate ICMP filtering between the tester and target or a misconfiguration in the traceroute capture.

BUSINESS IMPACT

This is an informational note with no direct security risk. It documents that the application infrastructure runs on a major public cloud provider, which is a common and generally acceptable architectural choice. The client should maintain accurate records of cloud asset ownership to support future penetration testing authorisation and incident response activities.

REMEDIATION

Ensure documented records of AWS account ownership and asset inventory are maintained and shared with penetration testing vendors at engagement commencement to streamline authorisation.

1. Confirm with the client that AWS account ownership of the EC2 instance at 44.228.249.3 is documented and that the engagement authorisation letter explicitly references this asset.
2. Review AWS's current Penetration Testing Policy (<https://aws.amazon.com/security/penetration-testing/>) to ensure all testing activities performed during this engagement were compliant.
3. Consider configuring Elastic IP addresses for externally tested EC2 instances to prevent IP reassignment between engagement sessions.
4. Enable AWS Config and CloudTrail on the AWS account to maintain an auditable inventory of cloud assets and detect unexpected configuration changes during and after the test.
5. If Shodan enrichment is desired for future engagements, configure SHODAN_API_KEY in pt-orc.conf to cross-reference open port listings against active scan results.

REFERENCES

<https://aws.amazon.com/security/penetration-testing/>

<https://aws.amazon.com/aup/>

<https://docs.aws.amazon.com/config/latest/developerguide/what-is-AWS-Config.html>

05 Remediation Roadmap

ID	Finding	Severity	Effort	Timeframe
F-001	Multiple HTTP Security Headers Missing	MEDIUM	Low	Short-term (1-4 weeks)

06 Disclaimer & Legal

IMPORTANT NOTICE

This report has been prepared solely for the use of the client organisation named in the engagement configuration and is intended to communicate the findings of a time-boxed penetration test conducted under formal written authorisation. The security posture described herein reflects the state of the target environment as observed during the testing window (June 2026) only and may not reflect vulnerabilities introduced or remediated after that date. Penetration testing is inherently a point-in-time assessment and cannot guarantee the discovery of all vulnerabilities present in the target environment. The absence of a finding in this report should not be interpreted as a confirmation that no vulnerability exists. TechGuard Labs has exercised professional care in the preparation of this report; however, no warranty, express or implied, is made as to the accuracy or completeness of the information contained herein. All testing was performed in accordance with the agreed Rules of Engagement, applicable laws, and the AWS Penetration Testing Policy. Redistribution of this report to third parties requires prior written consent from TechGuard Labs and the client organisation. Evidence files and working data referenced in this report should be stored securely and disposed of in accordance with the client's data retention and classification policies.

METHODOLOGY NOTES

This assessment was conducted as an external black-box web application penetration test (mode: pte) against the single in-scope target testphp.vulnweb.com (44.228.249.3) during June 2026. Testing followed a structured pipeline: (1) DNS reconnaissance and subdomain enumeration using amass, httpx, and certificate transparency logs; (2) IP ownership and ASN analysis with PTR, WHOIS, and traceroute enrichment; (3) Comprehensive TCP and UDP port scanning using masscan (rate 5000 pps) and nmap with NSE scripts covering common vulnerability categories including SSL/TLS weaknesses, SMB, RDP, shellshock, and FTP; (4) TLS configuration assessment across discovered HTTPS ports (443, 4443, 8443) using testssl.sh; (5) Web application enumeration covering 18 test cases including header and technology fingerprinting, security header and CSP analysis, CORS misconfiguration testing, WAF detection, directory and path discovery (gobuster + ffuf against dirb common wordlist), Nikto scanning, JavaScript secret extraction, cookie security analysis, open redirect detection, login page analysis, CMS detection, GraphQL introspection, OAuth2/OIDC discovery, and client-side security indicators; (6) API security review covering 20 test cases aligned to the OWASP API Security Top 10 (2023) including HTTP method enumeration, schema discovery, authentication bypass, rate limiting, CORS, BOLA/IDOR, mass assignment, JWT attacks, GraphQL attacks, SSRF/IMDS, XXE, SSTI, host header injection, shadow API discovery, sensitive data exposure, business logic flaws, WebSocket detection, and TLS checks; (7) Service vulnerability verification using Metasploit Framework with MSF database integration. Testing was conducted in accordance with the Rules of Engagement: no Denial of Service activity, testing restricted to the agreed window, and no production data exfiltration. Authentication level was none (unauthenticated testing only). The OWASP Testing Guide v4.2 and OWASP API Security Top 10 (2023) were used as the primary methodology references.